Encryption and Key Management Policy

POL-COMP-005 · Version 2.0 · Effective 2025-02-15

1. Purpose

The purpose of this Encryption and Key Management Policy (POL-COMP-005, version 2.0) is to establish guidelines for the encryption of sensitive data and the management of encryption keys within Acme Corp. This policy aims to protect the confidentiality, integrity, and availability of sensitive data processed and stored by the company's systems, particularly the Secrets Vault, Ledger DB, and Payment Gateway.

2. Scope

This policy applies to all employees, contractors, and third-party service providers who access or manage sensitive data within the Acme Corp environment. It encompasses all systems that process sensitive data, including but not limited to the Secrets Vault, Ledger DB, and Payment Gateway.

3. Policy Statements

3.1 Data Encryption

- Data at rest must be encrypted using AES-256 encryption standards to ensure the security of sensitive information stored in the Ledger DB and other relevant systems.
- Data in transit must utilize TLS 1.2 or higher to secure communications between internal and external systems, including the Payment Gateway.

3.2 Key Management

- Encryption keys used for data protection must be securely stored in the Secrets Vault to prevent unauthorized access and to maintain data confidentiality.
- Encryption keys must be rotated every 90 days to mitigate the risk of key compromise and to enhance overall data security.
- A documented key rotation process must be followed to ensure compliance with this policy. The process should include verification steps to confirm successful key rotation.

3.3 TLS Certificate Management

- TLS certificates used for securing data in transit must be renewed at least 30 days before their expiry to prevent service disruptions and to ensure ongoing protection against potential vulnerabilities.

• The owning team must maintain an inventory of all TLS certificates, including their expiration dates, to facilitate timely renewals.

3.4 Compliance with Related Policies

• This policy must be implemented in conjunction with related documents, specifically POL-COMP-001: Data Retention Policy, POL-COMP-004: Access Control Policy, and POL-COMP-008: Payment Card Data Handling Policy, to ensure comprehensive data security measures are in place.

• Employees must be familiar with the Acceptable Use Policy (POL-COMP-002) and adhere to the principles outlined therein when handling sensitive data.

4. Roles and Responsibilities

• The owning team is responsible for ensuring that encryption and key management practices are implemented in accordance with this policy.

• The on-call engineer must monitor the status of encryption mechanisms and report any anomalies or breaches immediately, following the Incident Response Policy (POL-COMP-003).

• The Incident Commander must coordinate responses to any incidents related to encryption failures or key management breaches, ensuring that all relevant stakeholders are informed and involved in the resolution process.

5. Exceptions

• Any exceptions to this policy must be documented and approved by the designated authority within the organization. Exceptions should include a rationale and a risk assessment that outlines the potential impacts of non-compliance.

• Temporary exceptions may be granted for specific projects or scenarios, but they must not compromise the overall security posture of the organization.

6. Enforcement

• Violations of this policy may result in disciplinary action, including termination of employment or contractual agreements, depending on the severity of the breach.

• Regular audits will be conducted to assess compliance with this policy and to identify any areas for improvement. Non-compliance discovered during audits must be addressed promptly and may lead to further investigation or action.

7. Related Documents

• POL-COMP-001: Data Retention Policy

• POL-COMP-002: Acceptable Use Policy

- POL-COMP-004: Access Control Policy
- POL-COMP-008: Payment Card Data Handling Policy

All employees are expected to familiarize themselves with this Encryption and Key Management Policy and adhere to its guidelines to ensure the protection of sensitive data within Acme Corp.